

by the Video Player to commission the Phone App without requiring the user to physically input a Setup PIN.

The account match is determined by the Content App using a method which is outside the scope of this specification and will typically involve a central service which is in communication with both the Content App and the Commissionee. The GetSetupPIN command is needed in order to provide the Commissioner/Admin with a Setup PIN when this Commissioner/Admin is operated by a different vendor from the Content App.

This method is used to facilitate Setup PIN exchange (for PASE) between Commissioner and Commissionee when the same user account is active on both nodes. With this method, the Content App satisfies proof of possession related to commissioning by requiring the same user account to be active on both Commissionee and Content App, while the Commissioner/Admin ensures user consent by prompting the user prior to invocation of the command.

Upon receipt of this command, the Content App checks if the account associated with the Temporary Account Identifier sent by the client is the same account that is active on itself. If the accounts are the same, then the Content App returns the GetSetupPIN Response which includes a Setup PIN that may be used for PASE with the Commissionee.

The Temporary Account Identifier for a Commissionee may be populated with the Rotating ID field of the client's commissionable node advertisement (see Rotating Device Identifier section in [\[MatterCore\]](#)) encoded as an octet string where the octets of the Rotating Device Identifier are encoded as 2-character sequences by representing each octet's value as a 2-digit hexadecimal number, using uppercase letters.

The Setup PIN is a character string so that it can accommodate different future formats, including alpha-numeric encodings. For a Commissionee it SHALL be populated with the Manual Pairing Code (see Manual Pairing Code section in [\[MatterCore\]](#)) encoded as a string (11 characters) or the Passcode portion of the Manual Pairing Code (when less than 11 characters).

The server SHALL implement rate limiting to prevent brute force attacks. No more than 10 unique requests in a 10 minute period SHALL be allowed; a command response status of FAILURE should be sent for additional commands received within the 10 minute period. Because access to this command is limited to nodes with Admin-level access, and the user is prompted for consent prior to Commissioning, there are in place multiple obstacles to successfully mounting a brute force attack. A Content App that supports this command SHALL ensure that the Temporary Account Identifier used by its clients is not valid for more than 10 minutes.

ID	Name	Type	Constraint	Quality	Fallback	Conformance
0	TempAccountIdentifier	string	16 to 100			M

6.2.4.1.1. TempAccountIdentifier Field

This field SHALL specify the client's Temporary Account Identifier. The length of this field SHALL be at least 16 characters to protect the account holder against password guessing attacks.